

Anlage 1 – Technische und organisatorische Maßnahmen (TOM)

1. Infrastruktur

KanuControl wird auf einer privaten Serverinfrastruktur des Auftragsverarbeiters betrieben.

Die Infrastruktur umfasst mehrere virtuelle Maschinen (VMs) unter Linux, die unterschiedliche Aufgaben übernehmen, insbesondere:

- Anwendungsserver
- Datenbankserver
- Authentifizierungsserver
- Reverse Proxy / Webserver
- Monitoring- und Verwaltungsdienste

Die Systeme befinden sich ausschließlich unter Kontrolle des Auftragsverarbeiters.

2. Zutrittskontrolle

Die Server befinden sich in privaten Räumlichkeiten des Auftragsverarbeiters.

Der physische Zugang ist ausschließlich dem Auftragsverarbeiter sowie ausdrücklich autorisierten Personen möglich.

Unbefugte Dritte haben keinen Zugang zur Hardware.

3. Zugangskontrolle

Administrative Zugriffe auf die Server erfolgen ausschließlich über:

- Benutzerkonten mit individuellen Zugangsdaten
- SSH-Zugänge
- Authentifizierung mittels kryptographischer Schlüsselverfahren
- Firewall-geschützte Netzwerkzugänge

Administrationszugänge werden ausschließlich für Wartungs- und Supportzwecke verwendet.

Die einzelnen Serverkomponenten sind durch Firewall-Regeln abgesichert.

Es wird das Prinzip der minimal erforderlichen Berechtigung (Least Privilege) angewendet. Netzwerkverbindungen zwischen den Systemen sind ausschließlich für die jeweils erforderlichen Dienste freigegeben.

Nicht benötigte Dienste und Ports sind deaktiviert oder durch Firewalls blockiert.

Administrative Zugriffe werden auf die hierfür erforderlichen Systeme und Protokolle beschränkt.

4. Zugriffskontrolle

Innerhalb von KanuControl erfolgt die Rechtevergabe rollenbasiert.

Benutzer erhalten ausschließlich die Berechtigungen, die zur Wahrnehmung ihrer Aufgaben erforderlich sind.

5. Netzwerksicherheit

Die Infrastruktur ist in mehrere logisch getrennte Systeme untergliedert.

Anwendungsserver, Datenbankserver, Authentifizierungsdienste, Monitoring-Systeme und Verwaltungsdienste werden getrennt betrieben.

Die Kommunikation zwischen den einzelnen Komponenten wird durch Firewall-Regeln kontrolliert und auf das technisch notwendige Maß beschränkt.

Direkte Zugriffe aus öffentlichen Netzen auf interne Dienste, insbesondere Datenbank- und Verwaltungsdienste, sind nicht vorgesehen.

6. Systemhärtung

Die eingesetzten Linux-Systeme werden nach dem Grundsatz der Systemhärtung betrieben.

Hierzu gehören insbesondere:

- Deaktivierung nicht benötigter Dienste
- Regelmäßige Sicherheitsupdates
- Beschränkung administrativer Zugriffsrechte
- Einsatz von Firewalls auf System- und Netzwerkebene
- Überwachung sicherheitsrelevanter Ereignisse
- Regelmäßige Überprüfung der Systemkonfiguration

Die Systeme werden fortlaufend gepflegt, um bekannte Sicherheitslücken zeitnah zu schließen.

7. Monitoring

Für die Infrastruktur werden Monitoring-Dienste eingesetzt.

Hierdurch können insbesondere folgende Ereignisse erkannt werden:

- Ausfälle von Diensten
- Ressourcenengpässe
- Fehlerzustände
- Auffälligkeiten im Systembetrieb

Die Überwachung dient der Sicherstellung von Verfügbarkeit, Integrität und Sicherheit der verarbeiteten Daten.

8. Mandantentrennung

KanuControl ist mandantenfähig aufgebaut.

Jeder Verein wird in einem eigenen Datenbankschema geführt.

Die Daten eines Vereins sind logisch von den Daten anderer Vereine getrennt.

Anwendungslogik und Datenbankzugriffe sind so gestaltet, dass Benutzer ausschließlich auf die Daten ihres jeweiligen

Vereins zugreifen können.

Eine Vermischung von Vereinsdaten unterschiedlicher Mandanten ist technisch ausgeschlossen.

9. Weitergabekontrolle

Die Übertragung von Daten zwischen Endgeräten und KanuControl erfolgt verschlüsselt über HTTPS/TLS.

Administrative Zugriffe erfolgen verschlüsselt über SSH.

10. Eingabekontrolle

Anmelde- und sicherheitsrelevante Vorgänge werden protokolliert.

Änderungen an Benutzerkonten und Rollen können nachvollzogen werden.

11. Verfügbarkeitskontrolle

Zum Schutz vor Datenverlust werden tägliche Datensicherungen erstellt.

Die Backups werden auf einer separaten externen Festplatte gespeichert, die unabhängig vom Produktivsystem betrieben wird.

Die externe Festplatte befindet sich unter Kontrolle des Auftragsverarbeiters.

Backups werden regelmäßig auf erfolgreiche Erstellung überwacht.

Zusätzlich erfolgt eine Überwachung der Infrastruktur durch Monitoring-Systeme, um Störungen frühzeitig zu erkennen.

Zusätzliche Ausfallsicherung

Für den Fall eines Ausfalls des primären Systemdatenträgers steht ein vorbereiteter Clone des Systemdatenträgers zur Verfügung.

Der primäre Systemdatenträger kann im Fehlerfall innerhalb kurzer Zeit durch den vorbereiteten Clone ersetzt werden. Anschließend können die seit Erstellung des Clones vorgenommenen Änderungen über die vorhandenen VM-Datensicherungen wiederhergestellt werden.

Zusätzliche Offline-Datensicherung

Einmal monatlich werden Kopien der virtuellen Maschinen auf einen separaten externen Datenträger erstellt.

Der Datenträger wird ausschließlich für die Durchführung der Datensicherung temporär mit dem Stromnetz verbunden. Nach Abschluss der Sicherung wird die Stromversorgung wieder abgeschaltet.

Außerhalb des Sicherungszeitraums ist der externe Datenträger nicht dauerhaft mit der Produktivinfrastruktur verbunden.

Diese zusätzliche Sicherung stellt eine weitere Wiederherstellungsmöglichkeit außerhalb des laufenden Produktiv- und Backupbetriebs bereit.

12. Wiederherstellbarkeit

Im Falle eines technischen Ausfalls können Daten aus den vorhandenen Sicherungen wiederhergestellt werden.

Bei einem Ausfall des primären Systemdatenträgers kann zunächst der vorbereitete System-Clone eingesetzt werden. Anschließend werden erforderliche Änderungen über die vorhandenen VM-Datensicherungen wiederhergestellt.

Die Wiederherstellung erfolgt ausschließlich durch den Auftragsverarbeiter.

Die Wiederherstellbarkeit der Systeme wird im Rahmen der betrieblichen Wartungs- und Sicherungsmaßnahmen überprüft.

13. Authentifizierung

Die Benutzeranmeldung erfolgt über einen zentralen Authentifizierungsdienst.

Passwörter werden nicht im Klartext gespeichert.

Der Authentifizierungsdienst unterstützt moderne Verfahren zur sicheren Anmeldung und Rechteverwaltung, insbesondere One-Time-Password (OTP).

14. Verfahren bei Datenschutzvorfällen

Werden dem Auftragsverarbeiter Sicherheitsvorfälle oder Datenschutzverletzungen bekannt, wird der Verantwortliche unverzüglich informiert.

Die Information enthält soweit möglich:

- Art des Vorfalls
- Zeitpunkt der Feststellung
- betroffene Datenkategorien
- bereits eingeleitete Gegenmaßnahmen

15. Löschkonzept

Nach Beendigung der Nutzung von KanuControl werden die Daten des Vereins auf Anweisung des Verantwortlichen gelöscht oder exportiert und übergeben.

Verbleibende Sicherungskopien werden im Rahmen der regulären Backup-Rotation überschrieben und entfernt.